

Phân biệt Dictionary Attack và Brute-Force Attack

Tiêu chí	Tấn công từ điển (Dictionary Attack)	Tấn công vét cạn (Brute-Force Attack)
Cách thức hoạt động	Thử lần lượt các từ nằm trong một danh sách có sẵn (từ điển mật khẩu, danh sách mật khẩu phổ biến, rò rỉ từ các vụ hack trước đó).	Thử tất cả các kết hợp ký tự có thể có (chữ cái, chữ số, ký tự đặc biệt) theo độ dài tăng dần cho đến khi tìm ra mật khẩu đúng.
Không gian tìm kiếm	Giới hạn trong danh sách từ điển đã chuẩn bị sẵn (vài nghìn đến hàng triệu từ).	Mở rộng vô hạn dựa trên tổ hợp ký tự (ví dụ: a^n tổ hợp với a là số lượng ký tự, n là độ dài mật khẩu).
Tốc độ & Hiệu năng	Tốc độ xử lý nhanh, tốn ít tài nguyên tính toán hơn do không gian tìm kiếm nhỏ.	Rất chậm và tốn rất nhiều tài nguyên tính toán (CPU/GPU), thời gian tăng theo mũ dựa trên độ dài mật khẩu.
Tỷ lệ thành công	Phụ thuộc vào thói quen đặt mật khẩu yếu của người dùng (từ dễ đoán, từ trong từ điển tiếng Anh/Việt, chuỗi số đơn giản như 123456).	Đảm bảo 100% sẽ tìm ra mật khẩu nếu có đủ thời gian và sức mạnh phần cứng.

Ví dụ cụ thể về cách phòng chống ở phía Máy chủ (Server-side)

1. Phòng chống Tấn công vét cạn (Brute-Force Attack)

- Giải pháp: Giới hạn số lần đăng nhập thất bại (Rate Limiting & Lockout Policy)
- Cách thức triển khai:

Máy chủ theo dõi số lần đăng nhập sai từ một tài khoản hoặc một địa chỉ IP trong một khoảng thời gian nhất định.

- Ví dụ: Nếu một tài khoản nhập sai quá 5 lần trong vòng 1 phút, máy chủ sẽ tạm khóa tài khoản hoặc chặn địa chỉ IP đó trong 15–30 phút, hoặc yêu cầu xác thực CAPTCHA ở các lần thử tiếp theo.

- Tác động: Điều này vô hiệu hóa hoàn toàn tấn công vét cạn vì hacker cần hàng tỷ lượt thử, nhưng máy chủ chỉ cho phép thử vài lượt mỗi phút.

2. Phòng chống Tấn công từ điển (Dictionary Attack)

- Giải pháp: Ràng buộc chính sách mật khẩu mạnh (Strong Password Policy) & Kiểm tra rò rỉ khi người dùng đặt mật khẩu
- Cách thức triển khai:

Khi người dùng đăng ký hoặc đổi mật khẩu, máy chủ sẽ thực hiện kiểm tra 2 lớp:

- Yêu cầu độ phức tạp bắt buộc: Tối thiểu 12 ký tự, bao gồm chữ hoa, chữ thường, chữ số và ký tự đặc biệt.
- Đối chiếu mật khẩu mới với danh sách "từ điển" các mật khẩu yếu/phổ biến nhất (như `password123`, `qwerty`,...) hoặc kiểm tra qua các cơ sở dữ liệu rò rỉ (như *API Have I Been Pwned*). Nếu phát hiện mật khẩu nằm trong danh sách này, máy chủ từ chối và yêu cầu người dùng chọn mật khẩu khác.
- Tác động: Loại bỏ khả năng người dùng đặt các mật khẩu dễ đoán nằm trong danh sách từ điển của hacker.